INTRODUCTION

Report on Different Cyber Attacks on Different Companies

STUDENT INFORMATION

NAME	Jainish A Gohel
ENROLLMENT	241105060039
CLASS	B
BATCH	B22

REPORT OVERVIEW

This report presents a study of different cyber attacks that have affected real-world companies and organizations. It introduces major attack methods, explains how attackers gained access, examines the impact of each incident, and highlights the security measures that helped limit the damage.

KEY FOCUS

Phishing • Pretexting • Baiting • Ransomware • Malware

Social engineering, real-world case studies, impact, and prevention strategies.

How to read this file

This is not a catalogue of every famous hack. It is five stories, picked because a person, not a broken padlock, was somewhere near the front door. Two of them are Indian. Three are not. Each story opens with a newspaper-style page, then a write-up you can actually finish in one sitting.

A note on the pictures, because it matters. The clippings are made for this report. They look like torn newsprint so the incident feels like something that landed on a desk, which is how these stories usually arrive. They are not photographs of Wikipedia, and they are not scans of The Indian Express or The New York Times. Dates, sums and company actions in the articles come from contemporary reporting and later official statements. Where a number was disputed in public, the text says so.

What sits where

1. Three tricks with ordinary names: phishing, pretexting, baiting
2. How to tell the three apart
3. Cosmos Bank, Pune — 11 to 13 August 2018 (India)
4. AIIMS Delhi — from 23 November 2022 (India)
5. Twitter — 15 July 2020 (United States)
6. Target — November to December 2013 (United States)
7. Uber — disclosed 15 September 2022 (United States)
8. What a tired Tuesday afternoon can still catch

If you only remember one line from the whole file, make it this: the expensive part is rarely the first click. It is the quiet hour after the click, when nobody is watching the odd login.

Why these five

Cosmos is here because the loss has a rupee figure and a clock: seven hours, 28 countries. AIIMS is here because the victim was not a balance sheet. It was a queue of patients. Twitter is the cleanest public example of a phone pretext. Target is the cleanest example of a vendor phish. Uber is the one where the second factor was already on, and still failed, because a person got tired of tapping no.

Each case has two kinds of page. The first is a clipping, staged for this file so the incident feels like news on a desk. The page after that is the account: history, method, the mess it left, and the fix. A third page on each case slows down and asks what a person in the building could have noticed.

A reading habit

On every case, mark two moments. The moment a human could still have said no. And the moment a machine should have said no even if the human did not. If a defence only has one of those, it is half a defence.

Three tricks with ordinary names

Social engineering is a dull phrase for a sharp idea. The attacker does not pick the lock. They talk someone into opening it. The tools have names that sound like sales training, which is half the point.

Phishing

A message that looks routine. A payroll notice, a vendor invoice, a password reset that “expires in 20 minutes”. The link or the attachment is the payload. In the Target story later in this file, the email did not even go to the retailer. It went to a small heating contractor that already had a login on the retailer’s network. That is spear-phishing: aimed, not sprayed.

Pretexting

A made-up reason to trust the caller. “I’m from IT, your session is stuck, read me the code.” The story is the weapon. Twitter’s 2020 incident was described by the company itself as a coordinated social-engineering attack on employees who could reach internal tools. Phone calls and convincing pretexts did the work that a stolen laptop did not have to do.

Baiting

Something left where curiosity will finish the job. The old classroom example is a USB stick in the car park labelled “salary review”. The modern version is a too-good link: double your Bitcoin, free software, a shared folder you were not expecting. The Twitter posts on 15 July 2020 were bait aimed at the public, after the staff door had already been talked open.

How a typical run goes

Almost every case in this file can be walked with the same four steps. The labels change. The shape does not.

1	**The approach** Email, phone call, or a prompt the person is tired of seeing.
2	**The hand-over** A password, a one-time code, or a click that installs a quiet program.
3	**The wander** The attacker uses a real login to reach a switch, a tool, or a till.
4	**The noise** Money moves, files lock, or a public account says something the owner did not say.

A useful habit while you read

For each case, mark the moment a human could still have said no. Then mark the moment a machine should have said no even if the human did not. Good defence needs both.

Same trick, three costumes

People mix these words up, which suits the attacker. A phish can carry a pretext. A bait can arrive as a phish. The label matters less than the question: what is this message asking me to hand over, and why now?

	Phishing	Pretexting	Baiting
Arrives as	Email or text that looks official	A phone call or a chat with a story	A tempting object or offer
Asks for	A click, a password, an attachment open	A code, a reset, a favour for IT	Curiosity: plug it in, send coin, open the file
In this file	Target’s vendor mail	Twitter’s calls to staff; Uber’s prompt flood	The Bitcoin posts; the old USB-in-the-car-park example
First habit	Hover, then call back on a known number	Refuse to read codes to a caller	If the offer is too neat, it is the hook

A mail you can practise on

Picture a Tuesday message. Subject: “Invoice overdue — account will be paused today.” The sender name says your usual vendor. The address is one letter off. There is a link, and a line about a late fee if you do not open it before 4 pm. Nothing in that mail needs a genius to spot. It needs a pause. The urgency is the point. Real finance teams can wait ten minutes while you check the address you already have on file.

The same pause works on the phone. A caller who will not let you hang up and ring the help desk back is not the help desk. Read-back of a one-time code is the hand-over. Once that code is spoken, the login is no longer yours. That is the Twitter shape and, in a quieter form, the Uber shape.

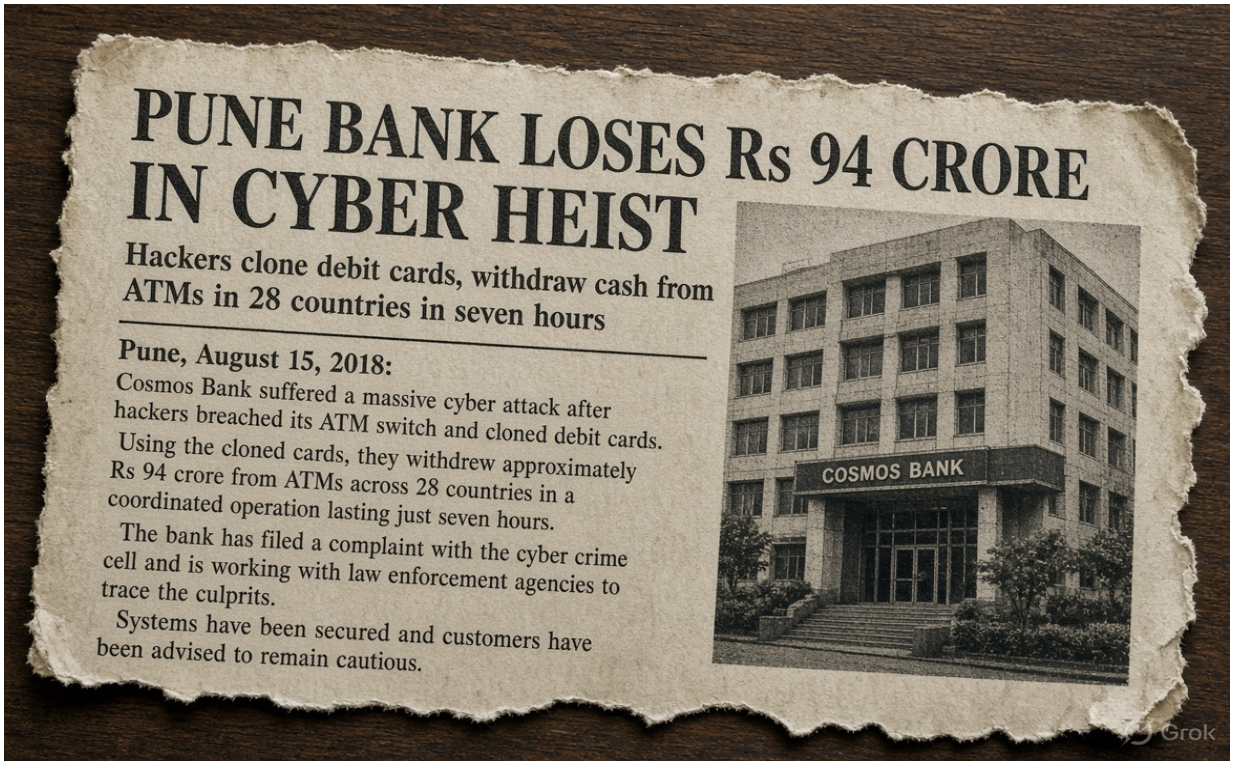
What the five cases share

1	**A real door** Vendor login, staff tool, hospital server, card switch, contractor account.
2	**A human shortcut** Trust, helpfulness, fatigue, or a mail that looked like Tuesday.
3	**A quiet stretch** Hours or weeks when the odd login was not owned by anyone.
4	**A loud ending** Cash, locked files, a public scam, or cards for sale.

None of the organisations in this file was empty of security tools. Cosmos had a core banking system. Target had paid monitoring. Uber had a second factor. The tools were there. The path around them was a person.

CASE 1 · INDIA

Cosmos Bank, Pune



Staged clipping for this report. Headline and figures follow reporting from August 2018.

The next page is the fuller account: when it happened, how the attackers got in, what the organisation had to live with, and what they did once the phones started ringing.

Case 1 · Cosmos Bank, Pune

On a Saturday afternoon in August 2018, cash started leaving a 112-year-old cooperative bank in Pune through ATMs the bank did not own, in countries the branch staff would not visit that week.

Organisation	Cosmos Bank, Pune, one of India's older urban cooperative banks
When	11 August 2018 (ATM run) and 13 August 2018 (SWIFT transfer)
What left	About Rs 94 crore in total, by the bank's own account to police
How	Malware on the ATM switch, cloned Visa and RuPay cards, then a fraudulent SWIFT payment
Who noticed first	Visa flagged odd overseas withdrawals; customers later saw balance mismatches

What the afternoon looked like

Between roughly 3 pm and 10 pm India time on Saturday 11 August, more than 12,000 ATM withdrawals in 28 countries took about Rs 78 crore on Visa cards. Inside India, about 2,800 RuPay transactions took another Rs 2.5 crore. On Monday 13 August a SWIFT payment of about Rs 13.5 to 14 crore went to a Hong Kong firm, ALM Trading Limited, according to the FIR as described in the Indian press. The total landed near Rs 94 crore.

Chairman Milind Kale told reporters the approvals came from malware that sat in front of the card network and said yes without asking the core banking system. Later write-ups described a proxy switch: a fake piece of the payment path that answered Visa and RuPay as if it were the bank. Cloned card data went onto plastic that could be used at real ATMs. This was a timed cash-out, the sort the FBI had already been warning banks about.

How the path ran

1	**Quiet break-in** Malware on the ATM switch, plus theft of card data.
2	**Fake approval desk** A proxy switch told Visa and RuPay the withdrawals were fine.
3	**Seven-hour rush** Cloned cards used in 28 countries and across India on 11 August.
4	**Second blow** A SWIFT transfer to Hong Kong on 13 August, before the switch was fully shut.

The problem on the bank's desk

Customers were told their own balances had not been emptied one by one; the loss sat with the bank. That did not make it small. A cooperative bank suddenly short Rs 94 crore has a capital problem and a trust problem at the same time. Visa services were stopped after the card network's alert, around 5 pm that Saturday, according to the police complaint as reported by The Times of India. RuPay was shut after cardholders called about mismatches. By then the overseas run was largely done. A complaint went to Chatushrungi police. The bank insisted the core system had not itself approved the ATM hits. That distinction mattered for customers. It did not bring the cash back.

What they did next

Card schemes were switched off, the odd switch was isolated, and the Hong Kong payment was reported. Audit and a police case ran in parallel. In February 2024 The Indian Express reported that 11 accused had been convicted, with the wider probe still open because the network of people stretched past India. Conviction is not the same as recovery. ATM cash that has already left a machine abroad rarely walks back.

Where it could have snagged

A payment switch that can approve cards without the core system is a single loud point of failure. Alerts on withdrawal velocity — thousands of hits in an hour, in countries the bank barely serves — should have frozen the scheme before the seventh hour. Vendor and switch access needed tighter monitoring, and the SWIFT desk needed a second pair of eyes on any new overseas beneficiary. None of that is exotic. It is the unglamorous checklist.

Cosmos, slowed down

The headline number is Rs 94 crore. The useful number is seven hours. That is the window in which a person or a rule could still have made the rest of the afternoon boring.

A clock, not a mystery

Saturday, about 3 pm	Overseas ATM withdrawals on cloned Visa cards begin to pile up.
Around 5 pm	Visa warns the bank. Visa services for Cosmos cards are stopped.
By 10 pm	The foreign run is largely over: about Rs 78 crore, 28 countries, 12,000-plus hits.
Same window, India	About 2,800 RuPay withdrawals, roughly Rs 2.5 crore, then RuPay is shut.
Monday 13 August	A SWIFT payment of about Rs 13.5–14 crore leaves for a Hong Kong firm.
That week	FIR at Chatushrungi police. Customers told their own balances were not the loss.

The bank's public line was that the core system had not approved the ATM hits. A proxy switch had. Think of it as a fake receptionist who kept saying "yes, that guest is expected" while the real register sat in another room. Card data had already been copied onto plastic. The people at the machines did not need to understand the malware. They needed a card and a city.

What the building had to live with

A cooperative bank does not shrug off Rs 94 crore. Capital, correspondent banks, and the Monday queue of depositors all feel it. The press camped on the story because it was easy to picture: cash, abroad, in an afternoon. Later reporting, including a February 2024 note in The Indian Express, said 11 accused had been convicted, with the wider trail still open. Court outcomes do not refill an ATM cassette in another country.

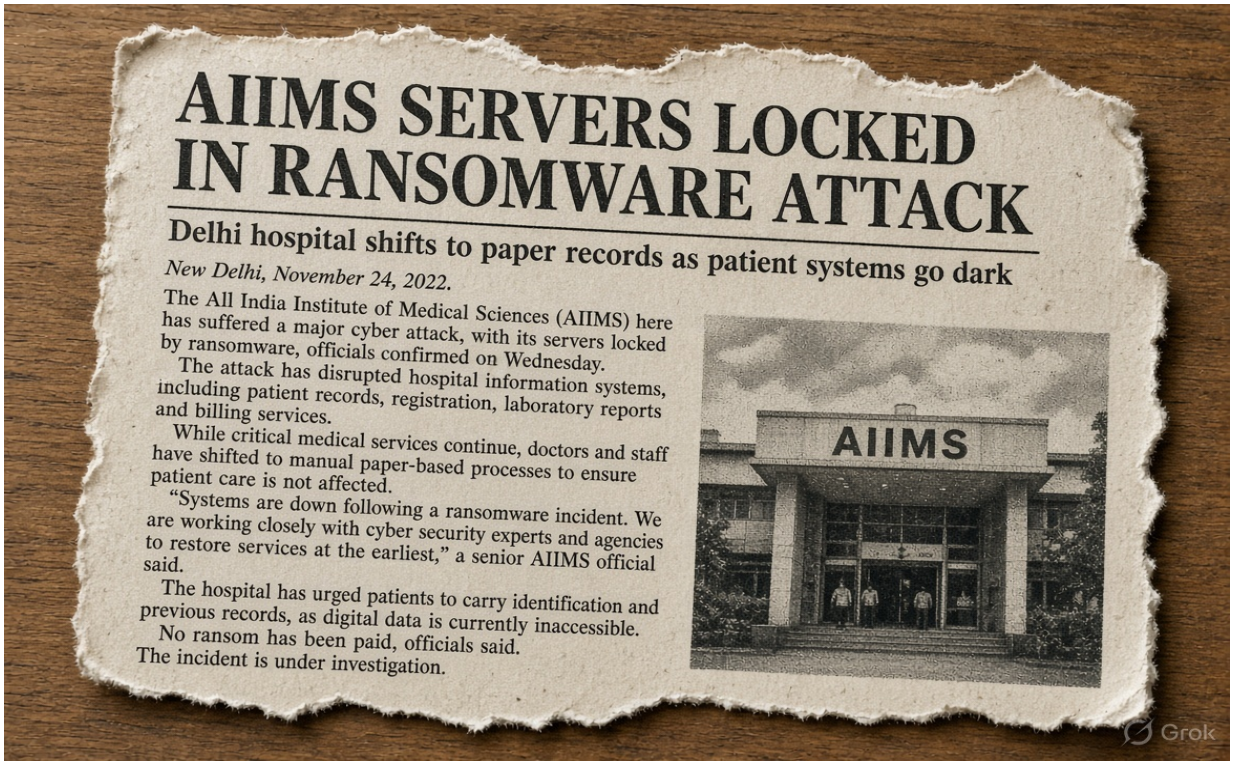
If this were a drill

1	**Count the hits** Thousands of foreign withdrawals in an hour is not a busy Saturday. It is a stop.
2	**One switch, two eyes** Anything that can approve cards without the core needs its own alarm.
3	**SWIFT is a second door** A new overseas beneficiary on Monday should not sail through on one login.
4	**Say it plainly** Tell customers what was and was not taken, the same day, in one voice.

None of that requires a new product. It requires someone whose job, on a Saturday, is to treat a strange graph as a reason to freeze first and explain second.

CASE 2 · INDIA

AIIMS, New Delhi



AIIMS SERVERS LOCKED IN RANSOMWARE ATTACK

Delhi hospital shifts to paper records as patient systems go dark

New Delhi, November 24, 2022.

The All India Institute of Medical Sciences (AIIMS) here has suffered a major cyber attack, with its servers locked by ransomware, officials confirmed on Wednesday.

The attack has disrupted hospital information systems, including patient records, registration, laboratory reports and billing services.

While critical medical services continue, doctors and staff have shifted to manual paper-based processes to ensure patient care is not affected.

"Systems are down following a ransomware incident. We are working closely with cyber security experts and agencies to restore services at the earliest," a senior AIIMS official said.

The hospital has urged patients to carry identification and previous records, as digital data is currently inaccessible.

No ransom has been paid, officials said. The incident is under investigation.

Staged clipping for this report. The outage began on 23 November 2022.

The next page is the fuller account: when it happened, how the attackers got in, what the organisation had to live with, and what they did once the phones started ringing.

Case 2 · AIIMS Delhi

A hospital can keep treating people with paper. It just cannot do it at the speed a city like Delhi expects, not when registration, lab reports and discharge all live on one set of servers.

Organisation	All India Institute of Medical Sciences, New Delhi
When	Servers corrupted from about 7 am on 23 November 2022
What broke	NIC e-Hospital servers: registration, appointments, labs, admissions
How	Ransomware on application, database and backup servers
Recovery	Data brought back from an unaffected backup; most functions up in about two weeks

The morning it stopped

The first complaint that morning did not come from a security dashboard. It came from the emergency lab, which could not open reports on the National Informatics Centre laboratory system. Primary and backup servers were already corrupted. Doctors moved to handwritten notes. Outpatient queues slowed. Patients were asked to bring old papers and identity cards, because the screen that usually knew them did not.

An FIR went to the Delhi Police Special Cell. CERT-In found four NIC servers infected, and later reporting added infections on computer-facility machines. A ransom-style note talked about a price. Newspapers carried a figure of Rs 200 crore. The health ministry later told Parliament that no specific sum had been confirmed by the hospital, though a message on the server showed it was an attack. Headlines and case files do not always match.

How the path ran

1	**A soft perimeter** CERT-In later found no real firewall policy and many unmanaged switches.
2	**Encryption** Ransomware locked e-Hospital servers, including one backup.
3	**Paper shift** OPD, labs and billing fell back to manual work from 23 November.
4	**Clean copy** An unaffected backup was used to rebuild on new, scanned servers.

The problem they had to live with

Care did not stop. It got slower and easier to mix up. A lab report that used to appear on a ward screen had to be walked across. Appointment lists had to be rebuilt by hand. Press reports spoke of records for crores of patients sitting on those systems, including people in public life. The official line, given in the Lok Sabha on 16 December 2022 by Minister of State Bharati Pravin Pawar, was that all e-Hospital data had been retrieved from a backup the attackers had not reached, and that registration, admission and discharge were mostly working again after two weeks.

Public reporting on the probe mentioned Proton Mail addresses created in Hong Kong and a file trail touching Henan in China. That is an early lead, not a finished attribution.

What they did

They did not, on the public record, pay. Antivirus was pushed onto thousands of machines. Servers were rebuilt. Endpoint hardening, stricter firewall rules and network segmentation were put in after the fact — the measures CERT-In had found missing. NIC and the hospital computer facility worked with police and national agencies. The dull lesson is the useful one: the backup that was not on the same network as the live servers is what saved the patient files.

Where it could have snagged

Unmanaged switches and a firewall with no policy are an open corridor. Segmentation would have kept a lab PC from reaching the database. A backup that cannot be encrypted from the live network is the difference between two weeks of paper and a lost archive. Staff still need a rehearsed paper plan, because the first morning of an outage is a bad time to invent one.

AIIMS, the fortnight after

A ransomware note is a short document. The hospital's problem was longer: every ward that had learned to trust a screen had to remember paper, in public, while the city watched.

What the days looked like

23 November, about 7 am	Emergency lab cannot open reports. Primary and backup servers are already corrupted.
That week	OPD, appointments and labs move to handwritten notes. Patients asked to bring old papers.
Early December	CERT-In describes a network with no real firewall policy and many unmanaged switches.
16 December	Health ministry tells the Lok Sabha that e-Hospital data came back from an untouched backup.
Same reply	Most registration, admission and discharge functions restored after about two weeks.
Ransom talk	Press figures circulated. The ministry said no specific sum was confirmed by the hospital.

The useful argument inside that table is the backup. One copy lived close enough to be encrypted. Another did not. The second copy is why this story is a fortnight of inconvenience and not a lost archive of patient files. Media reports spoke of records for crores of patients on those systems. The official line was that the data had been retrieved. Both sentences can be true: exposure was feared, and a clean copy was found.

What a ward actually does

A lab result that used to appear on a screen has to be walked. A discharge summary has to be written out. Identity has to be checked against a paper the patient brought, not against a file the hospital already held. None of that is dramatic. It is slow, and slow is how mix-ups happen. The doctors did not stop treating people. They stopped being able to pretend the computer was the memory.

A hospital checklist that matches this case

1	**Segment** A lab PC should not be able to reach the database that holds every record.
2	**One cold copy** A backup the live network cannot see, tested on a quiet week.
3	**Paper drill** One rehearsed morning of manual registration, before you need it.
4	**One voice** Say what is down, what is not, and that care continues. Rumours fill silence.

Probe notes mentioned mail addresses created in Hong Kong and a file hop touching Henan. That is a first layer. It is not a finished name for who did it. A hospital does not need the name to start the segmentation work.

CASE 3 · OUTSIDE INDIA

Twitter, July 2020



TWITTER ACCOUNTS OF FAMOUS NAMES HIJACKED IN BITCOIN SCAM

Staff tricked in phone social-engineering attack, company says

San Francisco, July 16, 2020. Hackers hijacked the verified Twitter accounts of several high-profile users on Wednesday, using them to post a fake Bitcoin giveaway scam.

The affected accounts included prominent figures in politics, entertainment, sports and business. Each posted similar messages promising to double Bitcoin sent to a specific digital wallet.

Twitter said the attackers used social engineering to trick employees and gain access to internal tools.

social engineering to trick employees and gain access to internal tools.

The company has since secured the accounts and is investigating.

The scam tweets were up for roughly 20 minutes before being removed. Some users reported sending small amounts of Bitcoin before realizing the posts were fraudulent.

Twitter said it is working with law enforcement and has taken steps to prevent similar attacks.

Staged clipping for this report. The hijack was on 15 July 2020.

The next page is the fuller account: when it happened, how the attackers got in, what the organisation had to live with, and what they did once the phones started ringing.

Case 3 · Twitter

For about twenty minutes on a Wednesday afternoon, some of the most watched accounts on the internet all said the same unlikely thing: send Bitcoin, and we will send back twice as much.

Organisation	Twitter (now X), San Francisco
When	15 July 2020, public posts from about 4 pm US East Coast time
What happened	Verified accounts posted a Bitcoin double-your-money scam
How	Phone spear-phishing of employees with access to internal admin tools
Public take	Widely cited tallies put the Bitcoin received above 100,000 US dollars

The pretext

Twitter's own account of it, posted that evening, was plain. Attackers ran a coordinated social engineering attack against employees who could reach internal systems. Later detail from the company and from prosecutors described phone spear-phishing: calls that convinced staff to hand over credentials, or to approve access, to tools that can change an account. Once those tools were open, the attackers did not need each celebrity's password. They posted as them.

The posts named, among others, Barack Obama, Joe Biden, Elon Musk, Bill Gates, Kanye West and Apple. The wording was the oldest bait on the platform, usually seen on fake lookalike accounts. The difference was the blue tick. People sent coin. Court papers in Florida later described a teenager in Tampa who had been offering, in a chat room, the ability to take over names. Three people were charged. The mastermind described in those papers was 17.

How the path ran

1	**A phone story** Employees with admin access were spear-phished by phone.
2	**The internal panel** Attackers used staff tools to post from verified accounts.
3	**The bait** A double-your-Bitcoin message went out in a short burst.
4	**The cutoff** Twitter locked down posting and reset the exposed access.

The problem they had to face

Money was the smaller wound. The larger one was that a handful of staff tools could speak for presidents and company founders. For the length of the scam, anyone watching those accounts had a reason to doubt the next real post. Twitter had to say, in public, that its own people had been talked out of the keys. Advertisers, regulators and users all heard that sentence.

What they did

They pulled the posts, limited verified accounts from tweeting while they checked the blast radius, and reset credentials. The company said it was looking for anything else the intruders had touched. In the weeks after, access to the admin tools was narrowed, and the incident became a standard lesson in security training: a help-desk voice on the phone is not proof of a help desk. Prosecutors took the criminal case. The product lesson stayed with the company.

Where it could have snagged

Admin tools that can post as any user should demand a second person, a hardware key, and an alert the moment they are used on a famous account. Phone resets should never be completed from a call the employee did not place. Pretexting works because people want to be helpful. The process has to be ruder than the caller.

Twitter, the twenty minutes

The posts were the bait. The breach was earlier, on the phone, with people whose job was to be able to fix an account. Helpfulness was the vulnerability. The blue tick was just the loudspeaker.

Two different crimes, one afternoon

It helps to split the day in two. First, staff with access to internal tools were talked out of that access. Twitter said so itself that evening: a coordinated social-engineering attack. Later accounts, including prosecutors in Florida, described phone spear-phishing. Second, once the tools were open, the attackers did not need each celebrity's password. They posted as them, for a short burst from about 4 pm on the US East Coast, promising to double any Bitcoin sent.

The names on the posts included Barack Obama, Joe Biden, Elon Musk, Bill Gates, Kanye West and Apple. The wording was an old scam, usually seen on fake lookalike accounts. The tick made it new. Widely cited tallies put the coin received above 100,000 dollars. Court papers described a teenager in Tampa who had been offering, in a chat room, the ability to take over names. Three people were charged. The person described as the mastermind was 17.

Why the tool was the real prize

1	**A call with a story** IT, a stuck session, a code that "expires".
2	**A panel that can speak** Admin access posts as the account. The owner's password never moves.
3	**A public bait** Double your Bitcoin, from a face people already trust.
4	**A short window** Twitter pulled posting rights while it checked what else had been touched.

After the hour, the company narrowed who could touch those tools and treated the episode as training. The sentence worth keeping is simple: a voice that says it is the help desk is not the help desk. Hang up. Ring the number on the intranet. If the caller cannot survive that pause, they were never IT.

What to rehearse

Once a quarter, have someone phone a colleague and ask for a login code, politely, with a plausible ticket number. The pass mark is a hang-up. The fail mark is a code read aloud. No one needs to be shamed. The point is to make the rude pause feel normal before a real caller tries the polite one.

CASE 4 · OUTSIDE INDIA

Target, holiday season 2013



RETAILER BREACH BEGAN WITH A VENDOR'S PHISHING EMAIL

Heating contractor's stolen password opened the door to 40 million cards

By David Chan MINNEAPOLIS, Dec. 20, 2013.

A phishing email sent to a heating contractor working at Target stores was the initial entry point for a massive data breach that exposed as many as 40 million customer payment cards, the company confirmed Thursday.

The contractor, a small firm based in Pennsylvania, had network access to Target's vendor portal. That access was used to install malware on the retailer's point-of-sale systems beginning in mid-November, according to people familiar with the investigation.

See BREACH, Page A12

efiany 2 2412 A12

The email tricked a contractor employee into revealing login credentials, Target said in a statement.

The vendor's account was then used to move laterally through Target's network.

The stolen data includes credit and debit card numbers, expiration dates and CVV codes, though not cardholder names, the company said.

Staged clipping for this report. The card theft ran from 27 November to 15 December 2013.

The next page is the fuller account: when it happened, how the attackers got in, what the organisation had to live with, and what they did once the phones started ringing.

Case 4 · Target

The door into one of America's largest retailers was not a till. It was a small heating and refrigeration contractor in Sharpsburg, Pennsylvania, with a login for sending bills.

Organisation	Target Corporation, Minneapolis
When	Network access from mid-November 2013; card theft 27 November to 15 December
What left	About 40 million payment cards; personal data on up to 70 million people
How	Phishing email to vendor Fazio Mechanical, then malware on store tills
Who rang the bell	The US Department of Justice, on 12 December, not Target's own first alert

The email that started it

Fazio Mechanical Services had remote access so it could file invoices and project papers. A phishing mail, reported later by journalist Brian Krebs and then by a US Senate Commerce Committee staff review, carried Citadel, a password-stealing cousin of the Zeus banking malware. The contractor was small. Reports at the time said its malware protection was a free tool. That is not a moral point. It is how supply chains actually look.

With a real vendor password, the attackers reached Target's external network and moved sideways. By the Black Friday weekend they had BlackPOS, also called Kaptoxa, on point-of-sale machines in nearly 1,800 stores. The malware read card data from memory while the till was asking the bank "may I?". Target later said unauthorised access to payment-card data ran from 27 November to 15 December 2013. The public heard about it on 19 December.

How the path ran

1	**Phish the vendor** Fazio Mechanical opened a malware mail and lost its login.
2	**Step inside** That login reached Target's vendor network.
3	**Walk to the tills** Card-stealing malware landed on point-of-sale systems before Black Friday.
4	**Missed bells** Security alerts fired. The Justice Department called on 12 December.

The problem on the shop floor

Forty million cards is not a statistic customers experience as a number. It is a reissued debit card in January, a fraud call, a Saturday spent on hold. Target faced lawsuits, a multistate settlement later reported at 18.5 million dollars, and a larger private bill for banks that had to reissue plastic. The chief executive left the following spring. Trust in a holiday brand is a slow thing to patch.

There is a second, quieter failure in the public record. FireEye, Target's monitoring system, raised alerts on 30 November and again on 2 December. They were not treated as the breach they were. The company has said it learned of the intrusion from the Department of Justice on 12 December, and pulled the malware on the 15th.

What they did

Malware was removed from the tills. Cards were flagged with banks. Target offered free credit monitoring, hired outside investigators, and later tightened vendor access so a refrigeration login could not wander toward a checkout. Chip cards, already on a US timetable, got a shove from this episode. None of that un-stole the numbers from the three weeks they were leaving the building.

Where it could have snagged

A vendor account should not see the till network. Phishing training at Fazio might have stopped the first mail; least-privilege access would have made the mail much less useful. The FireEye alerts were the last clean chance. An alert that nobody owns is just a log line.

Target, the vendor door

Fazio Mechanical Services was not a careless giant. It was a small heating firm with a login, because that is how bills get filed. The attackers did not need Target’s front door. They needed a side door that already had a key.

From a mailbox to a till

Before Black Friday	A phishing mail at Fazio carries Citadel, a password stealer. The vendor login is taken.
Mid-November 2013	That login is used on Target’s vendor network. The attackers move sideways.
27 November	Card-stealing malware is on point-of-sale systems as the holiday rush starts.
30 November and 2 December	FireEye raises alerts. They are not treated as the breach they are.
12 December	The US Department of Justice tells Target. The company has said this is when it knew.
15 to 19 December	Malware pulled on the 15th. The public hears on the 19th.

About 40 million payment cards and personal details on up to 70 million people left in that window. Malware sat in nearly 1,800 stores and read card data from memory while the till asked the bank for approval. Customers met the breach later, as a reissued card and a fraud call. Target faced lawsuits, a multistate settlement later reported at 18.5 million dollars, a larger private bill from banks, and a chief executive who left the following spring.

The alert that did ring

This is the part that should annoy anyone who thinks tools are the whole answer. The monitoring system noticed. Twice. An alert without an owner is a diary entry. The Justice Department, looking from the outside at stolen cards turning up, got there before the inside team closed the loop. That is an uncomfortable sentence. It is also the one worth putting in a training slide.

1	**Guest pass, not a badge** A refrigeration login reaches invoices. It does not reach a checkout.
2	**Own the bell** Name a person for each alert class. A bell with no name is decoration.
3	**Assume the vendor is small** Their mail protection may be a free tool. Your network has to survive that.
4	**Say it before the cards do** Three weeks of silence is how a holiday brand spends the next spring.

Chip cards in the United States got a shove from this episode. The shove did not un-steal the numbers from the weeks they were leaving the building.

CASE 5 · OUTSIDE INDIA

Uber, September 2022



RIDE-HAIL FIRM BREACHED AFTER CONTRACTOR TAPPED YES ON LOGIN PROMPT

Repeated approval requests wore down a worker, investigators say

San Francisco, Sept. 16, 2022. A ride-hail company's internal systems were breached after a contractor repeatedly approved login prompts, allowing an intruder to access sensitive data, investigators said.

The incident highlights the limits of multi-factor authentication when users face "fatigue" from repeated requests, officials said. The contractor received more than 100 login prompts over several hours before approving one from an unfamiliar device, according to the report.

The breach, which occurred in June, exposed personal information of a limited number of users, the company said. No financial data was accessed.

Investigators believe the attacker used social engineering and persistent MFA bombing to target the contractor's account. The company has since updated its access policies and added account lockout thresholds for repeated MFA denials.

This is a reminder that security depends on both technology and human judgment, officials said. Training on recognizing suspicious login behavior is now mandatory for all staff and contractors.

Staged clipping for this report. Uber posted its first notice on 15 September 2022.

The next page is the fuller account: when it happened, how the attackers got in, what the organisation had to live with, and what they did once the phones started ringing.

Case 5 · Uber

The login screen kept asking. Eventually someone tapped yes, just to make the buzzing stop. That is the whole attack, stripped of the brand names.

Organisation	Uber Technologies, United States
When	Disclosed 15 September 2022; company update on 19 September
What was reached	Internal tools, including Slack, finance invoices, and source repositories
How	A contractor password, then repeated two-factor prompts until one was accepted
Who Uber blamed	An attacker it linked to the Lapsus$ group

The tired yes

Uber's 19 September update is unusually direct. The company said the attacker likely bought a contractor's corporate password after malware on that person's own device had leaked it. The password alone was not enough. Each login attempt raised a two-factor approval on the contractor's phone. The contractor declined them. Then, after enough of them, accepted one. Security people call this MFA fatigue, or push bombing. It is pretexting with a mute button.

An alleged hacker had earlier claimed a simpler story: posing as corporate IT and asking for a password. Uber's investigation landed on the purchased password plus the prompt flood. Both versions are social engineering. Only one is the company's account.

From that single contractor account the attacker reached other staff accounts and internal tools: Slack, Google Workspace, a finance tool used for some invoices, and code stores. Uber said it took several internal systems offline, including Slack and cloud consoles, while it checked. The company said it did not see evidence that rider accounts or systems holding card data had been opened. Internal Slack messages and some invoice data were a different matter.

How the path ran

1	**Bought password** Malware on a contractor device, credential later sold.
2	**Prompt flood** Login attempts until one two-factor prompt was accepted.
3	**Wider keys** Other staff accounts and internal tools, including Slack.
4	**Public mess** Screenshots circulated; Uber took internal systems down to look.

The problem they had to face

For a company that moves people for a living, the fear is always the rider database. Uber's public line was that production systems with sensitive user data were not shown to be touched. The embarrassment was still real: an outsider reading internal chat, poking at bug reports, and posting proof. Staff had to be told which tools to trust that week. Contractors, who often sit outside the strictest device rules, were suddenly the front door.

What they did

They identified the contractor account, cut it off, and forced refreshes of credentials. Internal systems came back over the following days; Uber said services for riders were running again by 16 September. The company said it was adding tighter access rules and treating repeated approval denials as a signal, not as background noise. Lapsus$, the group Uber named, had already been linked that year to breaches at several technology firms, and British police had arrested teenagers accused of being in it. Naming the group did not close the hole. Changing the prompt did.

Where it could have snagged

A push notification that only says Approve is a trap. Number matching, or a hardware key, does not get worn down the same way. A burst of denied prompts should lock the account and call the user, not wait for the one tired yes. Contractors need the same device rules as staff if they hold the same kind of key.

Uber, the tired yes

Most people have tapped yes on a phone just to make a box go away. On 15 September 2022 that ordinary gesture was the breach. The password had already been bought. The second factor was supposed to stop the rest. It asked too politely, and too often.

What the company actually said

Uber's 19 September update is plain. A contractor's corporate password was likely bought after malware on that person's own device had leaked it. Login attempts then raised approval prompts. The contractor declined them, then accepted one. From that single account the attacker reached other staff accounts, Slack, a finance tool used for some invoices, and code stores. Uber took internal systems offline, including Slack and cloud consoles. It said it did not see evidence that rider accounts or card systems had been opened. Internal chat and some invoice data were a different matter.

An alleged hacker had claimed a simpler story: posing as IT and asking for a password. Uber's investigation landed on the purchased password plus the prompt flood. Both are social engineering. Only one is the company's account. Uber linked the attacker to Lapsus$, a group already tied that year to several technology firms. British police had arrested teenagers accused of being in it. Naming the group did not close the hole.

Why a yes/no buzz fails

1	**Prompt one** No. The contractor is doing something else.
2	**Prompt twenty** Still no. It is now an irritation, not a warning.
3	**Prompt enough** Yes, to make it stop. The login is no longer theirs.
4	**The fix** A code to type, or a hardware key. Denials should lock the account, not queue up.

Contractors are the quiet part of this story. They often sit outside the strictest device rules and still hold a key that opens staff tools. If the key is the same kind, the rule has to be the same kind. Uber said rider services were running again by 16 September, and that repeated denials would be treated as a signal. That is the right sentence. Fatigue is a setting you can change.

A test you can run without breaking anything

Ask a colleague to approve a login they did not start. If the phone only says Approve, the test has already failed, even if they tap no today. The prompt should name the place, the app, and a number they have to read back. A buzz with no detail is a favour waiting to be granted.

What a tired Tuesday can still catch

Read back across the five and the pattern is almost rude in its simplicity. Cosmos trusted a switch that could say yes by itself. AIIMS trusted a backup that lived too close to the thing it was backing up. Twitter trusted a phone voice. Target trusted a vendor login, and then trusted that someone would read the alert. Uber trusted a tap.

A short prevention list that matches these cases

Call the person back on a number you already have, not the number they gave you. That single habit blunts most pretexting.

Treat a vendor account as a guest pass, not a staff badge. It should reach the invoice folder and nothing that looks like a till, a switch, or a patient record.

Prefer a second factor that cannot be approved by fatigue. A code you must type, or a hardware key, beats a yes/no buzz. If you must use push approval, lock the account after a handful of denials.

Keep one backup where the live network cannot see it. Test the restore on a quiet week, not during the outage. AIIMS is the case that shows why.

Give alerts an owner. FireEye did ring at Target. A bell with no name next to it is decoration.

Freeze fast when the shape is wrong: thousands of ATM hits in an hour, a new SWIFT beneficiary, an admin tool posting as a public figure. Speed matters more than a perfect theory of who did it.

Side by side

Case	First human step	What limited the damage
Cosmos, 2018	Malware and cloned cards, not a single click in public view	Visa alert; card schemes shut; police case
AIIMS, 2022	Ransomware on a weakly segmented network	Untouched backup; no confirmed ransom paid
Twitter, 2020	Phone pretext against staff	Tools locked; posts pulled within the hour
Target, 2013	Phishing mail at a vendor	Malware pulled after an outside warning
Uber, 2022	Prompt fatigue on a contractor phone	Account cut; rider systems reported intact

None of these organisations was staffed by careless people having a cartoonishly bad day. They were busy. The attacker’s job was to sound like part of the busy. The defence that works is a little slower on purpose: a callback, a second approver, a login that cannot reach the till, a backup the ransomware cannot see. That is less exciting than a headline. It is also how the next headline gets smaller.

Sources used for dates and figures include contemporary reports in The Indian Express, The Times of India, India Today and Livemint on Cosmos Bank; Hindustan Times, The Indian Express and the 16 December 2022 Lok Sabha reply on AIIMS; Twitter’s own 15 July 2020 statements and US court reporting; the US Senate Commerce Committee staff account of Target and Brian Krebs’s vendor reporting; and Uber’s security updates of 15 and 19 September 2022. Clippings in this file are illustrations, not those sources.